

Digital Sovereignty In Practice

Roger Halbheer, Field CISO

Enterprise Security Perspectives / Security at AI Speed

A customer-facing framework for CISOs, security architects, procurement and regulator-facing teams: four sovereignty scenarios mapped to the EU Cloud Sovereignty Framework, the controls that answer them, the evidence that proves them, and what each one costs in money, people and speed.

Start here: this is the mechanics paper

The companion paper, *Sovereignty Is a Risk Decision*, made the argument. Sovereignty is risk management, not a posture you declare; it is paid for in money, people and speed; being compromised is not sovereignty; and untested sovereignty is not sovereignty.

This paper does not re-argue any of that. It assumes you accepted it and now have to build, buy, operate and evidence it.

What follows is the implementation layer: the EU Cloud Sovereignty Framework objectives and assurance levels, four scenarios with mitigations and tradeoffs, an evidence block for each one, the Microsoft control palette, and the NIS2 and DORA alignment.

Executive Summary

Digital sovereignty is the ability to keep control of your digital services, meaning your data, access, encryption keys, operations and continuity. You hold that control to meet local obligations. And to keep running when geopolitics, legal demands or provider dependencies get uncomfortable.

It is not "where the datacenter is". It is who can do what, under which laws, and what happens in an exception.

Customers care right now because three pressures are rising at once:

- **Regulation:** residency, auditability, NIS2 and DORA style oversight.
- **Trust and transparency:** who can access content during support and incidents.
- **Geopolitical continuity risk:** sanctions, export controls, or forced service suspension.

The result: CISOs are being asked to turn a fuzzy political term into concrete requirements that can be engineered and evidenced.

Sovereignty fails when it becomes theater: treating every workload as exceptional, or focusing on data location alone while ignoring key custody and operational access, adding cost and complexity without reducing real risk.

In October 2025 the European Commission published the Cloud Sovereignty Framework (v 1.2.1), a standardized approach for assessing the sovereignty of cloud services procured by EU institutions. ¹

Be clear about what it is before you build on it. It is an annex to a specific European Commission cloud procurement, drawing on CIGREF's Trusted Cloud Referential v2, the Gaia-X policy rules and the ENISA ², NIS2 and DORA landscape. ¹

It is procurement instrumentation, not a certification scheme. It has no regulatory force, no audit body and no published maintenance commitment. That is not a reason to ignore it. It is the clearest structured vocabulary currently available. It is a reason not to treat a level in it as a compliance status.

This paper makes sovereignty actionable by mapping customer requirements to that framework through four scenarios that show up repeatedly in real procurement and risk discussions.

The four scenarios:

- **S1** - Sanctions, service suspension, geopolitical "kill switch"
- **S2** - Extraterritorial laws, legal conflict, compelled actions
- **S3** - Supply chain and sustainability resilience (long-term autonomy)
- **S4** - Identity and control-plane dependency (architectural survivability)

Each scenario carries the same six parts: the sovereignty objectives it maps to, a description, a risk rating, mitigating actions split across people, process and technology, an evidence block, and a downside with a priced tradeoff.

Three scenarios are deliberately out of scope in this revision and are candidates for a later one: SaaS and workflow portability (functional sovereignty), economic coercion and pricing risk (commercial sovereignty), and the software update and signing trust chain (runtime trust sovereignty).

Why this matters now, and what "sovereignty" usually means

Outside the US, sovereignty is rarely a single requirement. Customers typically mean some combination of three things.

- **Control over data and AI:** where data is stored and processed, who can access it, key custody, auditability.
- **Jurisdictional resilience:** exposure to non-local laws with cross-border reach, and the enforceability of local rights.
- **Strategic continuity:** the kill switch fear, that a provider could be forced to suspend services because of sanctions, export controls or geopolitical pressure.

The Commission's Cloud Sovereignty Framework makes this explicit by defining eight sovereignty objectives (SOV-1 to SOV-8) and five graded levels of EU control (SEAL-0 to SEAL-4), rather than treating sovereignty as binary.¹

It is the structuring vocabulary throughout this document, used because it is the best available structure for the conversation, not because it carries regulatory weight. It does not.

Recommendation: do not buy a "sovereign cloud" as a slogan. Classify workloads, decide which sovereignty objectives actually matter for each, then apply the smallest set of controls that meet them: residency where needed, strict operational access transparency, and customer-controlled encryption keys.

Reserve fully isolated or customer-operated environments for the small set of must-run services where continuity outweighs cost, usability and innovation speed.

Sovereignty taxonomy, aligned to the EU Cloud Sovereignty Framework

The framework defines **eight objectives** and the factors that contribute to each, including legal exposure, operational oversight, key control, auditability, supply-chain provenance and sustainability. ¹

- **SOV-1 (Strategic Sovereignty):** Are services anchored in the EU ecosystem, and can operations continue if the provider is asked to cease or suspend service, or if support is disrupted?
- **SOV-2 (Legal and Jurisdictional Sovereignty):** Which laws can compel actions, and to what extent is the service insulated from external legal claims?
- **SOV-3 (Data and AI Sovereignty):** Where is data processed, who has effective control over cryptographic access, and how is AI usage and access audited?
- **SOV-4 (Operational Sovereignty):** Can EU actors operate, support and evolve the service without foreign dependency, and how portable is it?
- **SOV-5 (Supply Chain Sovereignty):** What non-EU dependencies exist in hardware, firmware, code and delivery chain, and what transparency and audit rights exist?
- **SOV-6 (Technology Sovereignty):** Is the stack open, interoperable and auditable, and can customers avoid irreversible lock-in and evolve independently?
- **SOV-7 (Security and Compliance Sovereignty):** Can security operations and compliance be evidenced under EU-aligned control expectations such as NIS2 and DORA?
- **SOV-8 (Environmental Sustainability):** Does long-term autonomy and resilience depend on energy and resource constraints, and is sustainability measurable?

Most of these objectives transfer to another jurisdiction by substitution. One does not. The contributing factors of SOV-1 (Strategic Sovereignty) include EU-sourced financing, investment and jobs within the EU, and involvement in EU initiatives, and those do not survive a find-and-replace of the jurisdiction name. ¹

So treat the set as a portable structure with one non-portable objective. SOV-2 through SOV-8 can be re-anchored to another jurisdiction usefully; SOV-1 has to be rebuilt against that jurisdiction's own industrial policy, if it exists at all.

National adaptations of this framework exist, and BSI's C3A is one of them. It adopts the framework's structure and objectives, turns its contributing factors into verifiable criteria, and deliberately omits SOV-7 (Security and Compliance Sovereignty), already covered by other BSI publications, and SOV-8 (Environmental Sustainability), which is outside BSI's remit; it "is not binding in itself". ³

SEAL levels: a scale of EU control, not of assurance rigor

Read this section carefully if you have seen SEAL described as an evidence-maturity ladder, because that description is wrong. SEAL does not grade how well evidenced a control is. It grades how much of the service is under EU control and how much sits with non-EU parties.

A note on the name, because it is a small trap. The document expands SEAL as Sovereignty Effectiveness Assurance Level where it defines the acronym, and as Sovereignty Effective Assurance Levels in its own section heading and again in section 5. **The inconsistency is in the source.** Use the full form sparingly and the acronym otherwise.

The five levels, per Cloud Sovereignty Framework v1.2.1, section 3: ¹

- **SEAL-0, No Sovereignty:** service, technology or operations under the exclusive control of non-EU third parties, governed entirely in non-EU jurisdictions.
- **SEAL-1, Jurisdictional Sovereignty:** EU law formally applies but with limited practical enforceability; the service is still under exclusive non-EU control.
- **SEAL-2, Data Sovereignty:** EU law is applicable and enforceable, with material non-EU dependencies remaining and indirect non-EU control.
- **SEAL-3, Digital Resilience:** EU law is applicable and enforceable, and EU actors exercise meaningful but not full influence, with marginal non-EU control remaining.
- **SEAL-4, Full Digital Sovereignty:** technology and operations under complete EU control, subject only to EU law, with no critical non-EU dependencies.

That changes what a SEAL level means in a conversation. Moving from SEAL-2 to SEAL-3 is not "we documented it better". It is a change in who controls the service, and it is bought with architecture, contracts and operating model, which is why it costs what this paper says it costs.

The framework grades control, not proof. Levels are assessed from tender answers, supporting evidence and public documentation. There is no test obligation anywhere in it.

That is a gap you should close yourself. Treat every SEAL level you claim as carrying a test obligation you impose on your own organization: name the exercise, the owner, the frequency, and the date it last ran. That obligation is not in the framework. It is what a NIS2 or DORA supervisor will ask you for anyway.

Stated as a rule: a SEAL level asserted in procurement is paperwork; a SEAL level you exercise on a schedule is sovereignty. The first half is the framework's; the second half is mine.

The Sovereignty Score, and where this paper disagrees with it

The framework has two components and most summaries describe only one. SEAL is the minimum assurance gate. Alongside it sits a weighted Sovereignty Score used as an award criterion, per section 5 of the same document.¹

The weights: SOV-5 (Supply Chain Sovereignty) twenty percent; SOV-1 (Strategic Sovereignty), SOV-4 (Operational Sovereignty) and SOV-6 (Technology Sovereignty) fifteen percent each; SOV-2 (Legal and Jurisdictional Sovereignty), SOV-3 (Data and AI Sovereignty) and SOV-7 (Security and Compliance Sovereignty) ten percent each; SOV-8 (Environmental Sustainability) five percent.¹

Read the weights correctly before you draw a conclusion from them. The document states that the weighting takes into account that the procurement procedure already contains significant safeguards in certain domains, naming SOV-2 and SOV-7.¹ **So the low weight on legal and on security is not a judgment that they matter less.** It is a statement that they are handled elsewhere in the same procurement. Anyone who reads the scoring table as a ranking of importance has misread it, and that misreading is common.

Now the conflict, because it is real and you should meet it before a tender does. This paper tells you to prioritize SOV-2, SOV-3, SOV-4 and SOV-7, which together carry forty-five percent of the score. It also tells you to treat full supply-chain sovereignty as an aspiration, not a default. SOV-5 alone carries twenty percent and is the single heaviest weight in the scheme.

Say it plainly: a reader who follows this paper's risk advice will score badly on the most heavily weighted objective in a tender scored on this framework. That is not a reason to change the risk advice. Risk-optimal and score-optimal are different objectives, and only one of them keeps you running.

How to handle it. Decide which of the two you are optimizing for, per procurement, and say so out loud in the bid or in the workshop. If you are being scored, invest in the SOV-5 evidence that is genuinely obtainable: supplier mapping, transparency and audit rights, substitution analysis. Do not pretend to a regional sourcing position that does not exist.

And record the divergence in your own risk register. A score-driven decision to buy SOV-5 assurance should stay visible as a procurement choice. Otherwise it is mistaken later for a risk judgment.

Implementation consequences

In customer discussions, sovereignty is often framed as a binary choice. It is critical to move away from that mindset and treat sovereignty as part of standard risk management.

The appropriate approach is a per-workload profile: one required SEAL level per objective, and a date proving you last exercised it.

The profile below is illustrative only. It is one defensible answer for a regulated but not must-run enterprise workload, and it is there to show the shape of the artifact, not to be copied.

Objective	Required SEAL level	Date last exercised
SOV-1 (Strategic Sovereignty)	SEAL-2	
SOV-2 (Legal and Jurisdictional Sovereignty)	SEAL-3	
SOV-3 (Data and AI Sovereignty)	SEAL-3	
SOV-4 (Operational Sovereignty)	SEAL-2	
SOV-5 (Supply Chain Sovereignty)	SEAL-2	
SOV-6 (Technology Sovereignty)	SEAL-2	
SOV-7 (Security and Compliance Sovereignty)	SEAL-3	
SOV-8 (Environmental Sustainability)	SEAL-1	

The third column is the whole point and it is mine, not the framework's. A profile with an empty date column is a wish list. Fill it from the exercise calendar later in this paper.

Note what the profile does not do: it does not demand SEAL-4 (Full Digital Sovereignty) anywhere. Full Digital Sovereignty means complete EU control with no critical non-EU dependencies, which is a must-run answer and not a default.

These choices affect architecture, operations and cost and should be weighed accordingly.

Risk assessment

Risk assessment is already established practice in most organizations. In the scenarios below, risk is the combination of two factors.

- **Likelihood:** Unlikely, Possible, Likely, Highly Likely, Almost Certain. The definitions vary from customer to customer.
- **Impact:** Insignificant, Minor, Moderate, Major, Critical. The definitions vary from customer to customer.

Ratings will vary by customer and by workload, and the two factors do not vary in the same way.

Likelihood is largely a property of your jurisdiction, your provider and your threat exposure, so it moves little between your own workloads. **Impact is a property of the individual workload** and moves enormously between them, which is why the same scenario can be a Critical risk for one system and Minor for another in the same organization. Combining the two gives a view of overall risk and lets you prioritize scenario by scenario, workload by workload.

Lower-risk scenarios should not be ignored, but this approach directs focus. By integrating sovereignty scenarios into the broader risk register, the discussion shifts from emotion or external pressure to a structured, consistent, risk-based approach aligned with other business risks.

How to read the evidence blocks

Every scenario carries a block called "How you would evidence this". It has three parts.

- **Contractual evidence:** the clauses that bind the provider, read as contract text rather than as a press release.
- **Technical evidence:** the configuration, inventory and log artifacts showing the control is live.
- **The test:** the exercise proving the control works under time pressure, with an owner, a frequency, and the date it last ran.

The test is the part organizations skip. A control that has never been exercised is a control you are assuming, not a control you have.

How to read the cost lines

Every scenario's downside ends with a priced line in three named currencies: money, people and speed.

- **Money** is the capital and running cost, the line a business case already knows how to carry.
- **People** is the standing headcount the control needs, and it is the currency organizations most consistently underprice.
- **Speed** is the capability and the adoption tempo you give up, paid every day the control is in force.

The four sovereignty scenarios

Four scenarios cover the large majority of customer sovereignty conversations, mapped to the Cloud Sovereignty Framework objectives. They are numbered S1 to S4 in this revision.

All four are exposures, things that can happen to you, and the controls that answer them sit in the mitigating actions under each scenario and in the Microsoft-centric control palette.

Legend: "Primary" marks an objective the scenario is mainly about, "Secondary" one it touches materially. A blank cell means the scenario does not drive that objective.

Scenario	SOV-1	SOV-2	SOV-3	SOV-4	SOV-5	SOV-6	SOV-7	SOV-8
S1 - Sanctions / service suspension / geopolitical "kill switch"	Primary	Secondary		Primary	Secondary	Secondary	Secondary	
S2 - Extraterritorial laws / legal conflict / compelled actions	Secondary	Primary	Secondary	Secondary			Secondary	
S3 - Supply chain and sustainability resilience (long-term autonomy)	Secondary			Secondary	Primary	Secondary	Secondary	Primary

Scenario	SOV-1	SOV-2	SOV-3	SOV-4	SOV-5	SOV-6	SOV-7	SOV-8
S4 - Identity and control-plane dependency (architectural survivability)	Primary		Secondary	Primary		Secondary	Primary	

Scenario S1 - Sanctions, service suspension, geopolitical "kill switch"

Mapped

Primary: SOV-1 (Strategic Sovereignty), SOV-4 (Operational Sovereignty).

Secondary: SOV-2 (Legal and Jurisdictional Sovereignty), SOV-5 (Supply Chain Sovereignty), SOV-6 (Technology Sovereignty), SOV-7 (Security and Compliance Sovereignty).

Description

Customers fear a foreign administration could force a provider, through sanctions, export controls or restrictions on service provision, to suspend some or all digital services. The Cloud Sovereignty Framework explicitly calls out the need to sustain operations against requests to cease or suspend a service, and against disrupted vendor support.¹

Sanctions practice can include restrictions on providing cloud-based services and SaaS categories for certain destinations, which demonstrates that service delivery can be targeted as a policy instrument.⁴

The one well-documented hyperscaler cutoff of a whole country's customers points the other way from the usual fear. In March 2024 Microsoft notified Russian customers, through distributor Softline, that it would suspend access to cloud products. The step complied with the twelfth EU sanctions package, adopted in December 2023. The letter stated: "After March 20, 2024, you will no longer be able to access these Microsoft products or services, or any data stored in them."⁴

The trigger was EU sanctions, not US action. The pull in this scenario is toward an environment that can run with no provider at all; the instrument that actually fired was European law.

Risk

- **Likelihood: Unlikely to Possible**, with higher perceived concern for public sector and critical operators. Service-restriction instruments demonstrably exist and have been used.
- **Impact: Critical** for must-run services (public services, critical infrastructure), because this is an availability and continuity failure mode.

Mitigating Actions

- **People:** Assign a cross-functional owner (CISO plus Legal plus Risk) for geopolitical and service-continuity risk, and maintain board visibility for critical services.
- **Process:** Implement and test exit plans (data export, identity, application portability, runbooks) and define a "minimum viable operations" baseline for crisis continuity.
- **Technology, for most workloads:** Use Sovereign Public Cloud controls and architect for portability, reducing single-point dependency while retaining hyperscale benefits.
- **Technology, for must-run workloads:** Use Sovereign Private Cloud (customer-operated), combining Azure Local and Microsoft 365 Local.

- **Know exactly what Microsoft 365 Local is, because the name misleads.** It is subscription editions of Exchange Server, SharePoint Server and Skype for Business Server running on Azure Local, generally available through a certified partner and supported through at least 2035. It is not the Microsoft 365 cloud service. Choosing it means giving up Teams, Copilot and the cloud-delivered security and compliance stack for those workloads.⁵
- **Technology, edge and offline transition:** Azure Stack Edge⁶ and Azure Data Box⁷ enable staged or emergency data movement and local processing when cloud connectivity is unavailable or intentionally severed.
- **State the limit, because it collides with S4 (Identity and control-plane dependency) if you do not.** Azure Stack Edge devices are ordered, activated and managed through the Azure portal. So treating them as the transition path out of a severed Azure relationship breaks S4's own rule: a recovery path must not depend on the control plane it is meant to recover. Disconnected operation is a rugged SKU capability, not a general one. Confirm which SKU and which capability you are actually buying, and test it before you rely on it.
- **Technology, national partner clouds where available:** Local partner-operated sovereign implementations designed to meet country-specific frameworks. Availability and scope vary by geography.

How you would evidence this

- **Contractual:** The suspension, notice-period and data-return clauses in the agreement, and any commitment by the provider to contest a government order. On 30 April 2025 Microsoft published its European Digital Commitments. In them it undertakes to promptly and vigorously contest, including in court, any government order anywhere in the world to suspend or cease its cloud operations in Europe. It also undertakes to write that commitment into contracts with European national governments and the European Commission.⁸
- **Then make it a comparison, not a citation.** Ask every provider on the shortlist for the equivalent clause in writing, and compare the contract text rather than the press release. What matters is the wording that binds, and whether it survives into your agreement.
- **Technical:** A current export inventory (what data, in what format, to where), a documented minimum viable operations baseline, and evidence that the target environment for the exit actually exists and has capacity.
- **The test:** A timed exit rehearsal for one nominated critical workload, at least annually. Measure time to restore the service to the minimum viable baseline, not time to copy the data. Record what failed.
- **The failure signature:** An exit plan with no owner, no target environment, and no recorded execution date. That is the Anhalt-Bitterfeld shape of failure: in July 2021 the district declared Germany's first cyber Katastrophenfall⁹, and the recovery cost it approximately EUR 2.5 million on its own figure.¹⁰ The rebuild is not gated by the plan, it is gated by the ability to direct and pay the people who have to run it.

Downside / tradeoff

Private and local sovereign environments reduce hyperscale cloud benefits, and Microsoft states the tradeoff itself. Its sovereign cloud documentation says that "Azure local and private clouds provide the strongest sovereignty controls by offering full control over hardware, software, data, location, and management. However, those environments don't deliver the full cloud value in areas such as cost-effectiveness, scalability, speed of innovation, security, and reliability."¹¹

Read that list, because it is broader than the one usually quoted back. It is not only cost and agility. It names scalability, security and reliability as well.

They typically cost more, reduce functionality, and add a significant talent burden: scarce platform, identity and security skills, plus patching, backup and disaster recovery, 24/7 coverage, and disciplined runbooks to stay reliable under stress.

The self-operation burden is not hypothetical, and the public record is specific. Exchange Server 2016 and 2019 left support in October 2025.¹² Microsoft is not consistent on the day: its lifecycle page gives 15 October 2025 and its roadmap page 14 October 2025. Two weeks after it happened, the German federal security authority counted the servers in its own country. Of roughly 33,000 German on-premises Exchange servers with internet-facing Outlook Web Access, 92 percent were still running 2019 or older.¹²

Then the number that needs no percentage. Security updates for those versions now arrive only through the Extended Security Update program, which Microsoft describes as "a last resort paid option for customers who need to run certain legacy Microsoft products past the end of support".¹³ Only organizations enrolled in the Period 2 ESU program receive 2016 and 2019 security updates, and Microsoft states that this program "is valid between May and October 2026".¹⁴ In late August 2026 the German CERT could see nine servers in the country with those patches installed.¹⁵

Read it as a statement about self-operation, not about one product. Owning the building, the hardware and the administrators is the part these organizations kept. Patching at population scale is the part that did not happen. Substitute any other self-hosted platform and the caution should hold. If it holds only for Exchange, it is a sales pitch.

What it costs.

- **Money:** duplicated platform, licenses and hardware refresh for an environment that may never be used in anger.
- **People:** a permanent 24/7 operations and engineering team in the scarcest part of the labor market, where 33 percent of ISC2 respondents already report insufficient resources to staff teams adequately.¹⁶
- **Speed:** a permanent position below the capability frontier, and slower feature adoption every single day, to insure against an event that may never fire.

Scenario S2 - Extraterritorial laws, legal conflict, compelled actions

Mapped

Primary: SOV-2 (Legal and Jurisdictional Sovereignty).

Secondary: SOV-1 (Strategic Sovereignty), SOV-3 (Data and AI Sovereignty), SOV-4 (Operational Sovereignty), SOV-7 (Security and Compliance Sovereignty).

Description

Customers worry that non-local laws with cross-border reach can compel actions or create legal uncertainty even when services run inside the local jurisdiction. That is exactly what SOV-2 evaluates.

The mechanism that creates exposure is not nationality. It is that a provider holds data, or holds the ability to access it, and is within reach of some state's compulsion. Every provider is within reach of at least one such state. Relocating data or changing the flag on the provider changes which government can compel, not whether some government can.

The EU Blocking Statute does not do what it is usually said to do

One correction, because it appears in almost every sovereignty deck. Regulation (EC) No 2271/96 protects only against the legislation listed in its Annex, and the Commission states that the Annex "currently consists of U.S. measures concerning Cuba and Iran".¹⁷ The CLOUD Act is not in that Annex, so the Blocking Statute offers no protection against it.

It is also not getting stronger on any published timetable. A 2021 Commission initiative to amend it reached inception impact assessment on 2 August 2021 and public consultation, opened on 9 September 2021 and closed on 4 November 2021. No legislative proposal has followed, and the Regulation remains unamended since 2018.¹⁸

The companion paper makes the full argument.

The legal picture is not one-sided

These powers exist because societies asked for them. Democracies hold them to pursue terrorism, child abuse and human trafficking. The question is not whether they should exist. It is whether they are bounded.

One line per instrument, because the list is the argument.

- **United Kingdom:** Investigatory Powers Act 2016 section 253, a technical capability notice reaching operator-applied protection and persons outside the UK.¹⁹
- **France:** compelled decryption, within 72 hours, by providers of cryptology services.²⁰
- **Switzerland:** BUEPF covers derived communications services²¹ on a lighter tier²² the Federal Council can raise case by case²³, and NDG Article 43(2) requires operators to remove encryption they applied.²⁴
- **China:** Data Security Law Article 36, general rather than annex-limited.²⁵
- **European Union:** the e-Evidence Regulation compels a provider directly across a border.²⁶

The powers are broadly comparable; the constraints are not. Germany's Federal Constitutional Court bound German surveillance to the Basic Law even abroad, with no US equivalent.²⁷ Providers publish commitments to redirect, notify and challenge²⁸, and Microsoft has litigated the point.²⁹

So this is not a US-only question. The companion paper argues it in full.

Risk

- **Likelihood: Unlikely to Possible** depending on sector, footprint and exposure. EU guidance emphasizes mapping transfers and assessing protections.³⁰
- **Impact: Major to Critical** for public sector and regulated industries, because of enforceability and trust consequences.

Mitigating Actions

- **People:** Assign a named owner for jurisdictional exposure who sits between Legal and Architecture, and give that person authority to pre-clear patterns rather than review every case.
- **Process:** Maintain "know your transfers" discipline and a documented approach to risk assessment and supplementary measures. Follow EDPB Recommendations 01/2020 on measures that supplement transfer tools³⁰, which carry the actual authority here.
- **Process:** Pre-authorize the common cases. Legal review in the critical path of every new feature converts a governance requirement into a permanent adoption delay.
- **Technology:** Minimize cross-border processing and strengthen cryptographic and operational controls: residency and support-data paths, approval gates on privileged provider access, customer-controlled keys, and telemetry you can still use where you hold it. The control palette later in this paper lists each of them.
- **Legal:** Understand the Blocking Statute's actual scope, its notification duty and its derogation path¹⁷. Treat it as a governance tool for the measures in its Annex, not as a technical control and not as CLOUD Act protection.

How you would evidence this

- **Contractual:** The provider's law-enforcement response commitments, notification-where-permitted clauses, litigation commitments, and the transparency reporting it publishes. Note that transparency reports are self-declared and not externally audited.
- **Technical:** A current transfer map showing which data categories can be reached by which jurisdiction, and through which processing path. Add evidence of which data classes are held under customer-controlled keys, and are therefore not producible as plaintext by the provider.
- **The test:** A legal-demand tabletop, at least annually, run against a real service. Someone plays the order, someone plays the provider. You measure how long it takes to answer three questions: what data is in scope, who must be notified, and what could be produced in plaintext.
- **The failure signature:** A transfer map that lags the live tenant by two quarters. It is a document about a system you no longer operate.

Downside / tradeoff

Legal and process overhead is ongoing: maintaining transfer maps, running Transfer Impact Assessments, updating contracts and supplementary measures, and managing Blocking Statute obligations and derogations is continuous governance work.

In practice this lengthens procurement cycles and slows change management. Legal review and evidence collection must keep pace with new services, features, vendors and cross-border support scenarios, especially in regulated sectors.

What it costs.

- **Money:** external counsel across multiple jurisdictions, and assessment work that recurs with every service change.
- **People:** a scarce hybrid skill set (privacy counsel who can read an architecture diagram) that most organizations do not have and cannot easily hire.
- **Speed:** latency of adoption. You fall behind not because the technology is worse but because the

approval is slower, and that is a cost paid every quarter against a risk that may never fire.

Scenario S3 - Supply chain and sustainability resilience (long-term autonomy)

Mapped

Primary: SOV-5 (Supply Chain Sovereignty), SOV-8 (Environmental Sustainability).

Secondary: SOV-1 (Strategic Sovereignty), SOV-4 (Operational Sovereignty), SOV-6 (Technology Sovereignty), SOV-7 (Security and Compliance Sovereignty).

Description

The framework evaluates supply-chain sovereignty through the origin and transparency of critical components, and sustainability through long-term resilience to energy and resource constraints.

The mitigating actions improve visibility and contingency options, but market reality is the twist. For chips, firmware supply chains, hyperscale platforms and energy-dense datacenter infrastructure, supplier diversity is limited and capacity is concentrated. Switching is slow and costly, if it is possible at all.

The companion paper makes the harder claim, and this paper accepts it rather than repeating it. No European organization can buy a fully independent stack. The dependency chain runs from silicon and firmware through package distribution and root trust to the DNS root zone. It leaves Europe within a few steps.

Frame that as concentration risk, not as an American problem. The point is not that any one country behaves badly. It is that critical capability sits concentrated where a board would never choose to place it, and no purchase changes that. So reduce the specific dependencies that matter for a workload, and stop pricing an independence that is not for sale.

Most organizations can realistically reduce dependency risk only for a narrow set of truly critical workloads. For the majority of services, resilience comes from multi-region design, tested exit and portability runbooks, and procurement leverage, rather than from achieving full regional sourcing end to end.

Risk

- **Likelihood: Likely.** Supply and energy disruptions are recurring, although the effect varies by sector.
- **Impact: Major** for critical services dependent on specialized hardware or constrained locations.

Mitigating Actions

- **People and Process:** Map key suppliers, require contractual transparency, define substitution and exit plans, and keep procurement evidence aligned to SOV-5 and SOV-8.
- **Technology:** Use portability and resilience patterns: multi-region design, tested recovery, documented exit runbooks.
- **Technology, exceptional cases only:** Consider local operating models to reduce dependence on specific external supply chains.

How you would evidence this

- **Contractual:** Supplier disclosure and audit rights, subcontractor change notification, component

provenance commitments, and the sustainability metrics the provider is willing to be measured on.

- **Technical:** A maintained supplier and dependency map for critical services, including the fourth party layer, plus SBOM coverage where it is obtainable.
- **The test:** A substitution walkthrough for one critical dependency per year. Do not test whether an alternative exists on a slide; test whether your team can procure, integrate and operate it, and how long that takes.
- **The failure signature:** A substitution plan whose alternative supplier has never been contacted, qualified or contracted. That is a list, not a plan.

Downside / tradeoff

The mitigating actions look tidy on paper and become costly paperwork sovereignty if applied broadly. Deep supplier mapping and transparency demands slow procurement and often meet vendor pushback, while exit and substitution plans are rarely realistic or exercised enough to be credible.

Portability patterns help but add engineering and operating cost, and in a concentrated market switching is slow and uncertain.

Local operating models reduce specific dependencies but reintroduce platform cost, staffing burden and innovation drag. Reserve the strictest measures for truly critical services and treat full supply-chain sovereignty as an aspiration, not a default baseline.

What it costs.

- **Money:** procurement overhead, dual-sourcing premiums, and engineering for portability you may never exercise.
- **People:** supplier risk management is a discipline with its own headcount, and it competes for the same budget as detection and response.
- **Speed:** the frontier is concentrated because that is where the capability is. Diversifying away from it today usually means operating with second best. It also slows every procurement decision behind a transparency questionnaire.

Scenario S4 - Identity and control-plane dependency (architectural survivability)

Mapped

Primary: SOV-1 (Strategic Sovereignty), SOV-4 (Operational Sovereignty), SOV-7 (Security and Compliance Sovereignty).

Secondary: SOV-3 (Data and AI Sovereignty), SOV-6 (Technology Sovereignty).

Description

S1 (Sanctions, service suspension, geopolitical kill switch) asks whether a provider could be forced to cut you off. S4 (Identity and control-plane dependency) asks what actually fails first when it happens. This is architectural survivability, and it is a different question from geopolitics (S1) and from access control.

The dependency is the identity, policy and control plane: the identity provider, MFA and conditional access, policy distribution, management APIs, certificate and token issuance. Customers ask three questions directly: can authentication still work, can the identity provider be replaced, and how long can we run disconnected.

Most organizations overestimate the answer to the third question badly, because they have never timed it. The honest measurement is not how long the data survives; it is how long people can still log in, approve, and change something.

The same independence that survives a blackout weakens the controls that protect you every other day. A system you can fully detach from is a system that cannot enforce access decisions centrally, govern automated actors, or respond at machine speed. Survivability and control speed pull against each other here more than anywhere else in this paper.

The control-plane risk that has actually fired is not geopolitical, it is ordinary. This is Microsoft's own account, per its MSRC and Security blog posts of 19 and 25 January 2024. In January 2024 "Midnight Blizzard utilized password spray attacks that successfully compromised a legacy, non-production test tenant account that did not have multifactor authentication (MFA) enabled".³¹ From there the actor reached an OAuth application with elevated permissions, and then corporate email.

Read the fact pattern carefully. An unretired legacy identity plus an over-permissioned OAuth application defeated the security program of the world's largest security vendor. Neither defect has anything to do with jurisdiction, and no amount of residency would have changed the outcome.

Name the other Microsoft case too, because a critic will. In 2023 the actor tracked as Storm-0558 forged authentication tokens with a stolen signing key, the secret used to vouch for logins. It then read the mailboxes of government customers. On the review board's count that reached 22 organizations and more than 500 individuals.³²

The US Cyber Safety Review Board found that intrusion preventable. It faulted a corporate culture that had deprioritized security investment. Both cases are identity failures. Neither is a jurisdiction failure, and no residency control would have stopped either.

Governance of non-human identity is therefore the control, and it is independent of where the data sits. An organization that cannot inventory its service principals and legacy accounts does not have a sovereign control plane, whatever the contract says.

Risk

- **Likelihood: Likely** for identity-plane compromise through legacy accounts, standing privilege and over-permissioned applications; **Unlikely to Possible** for a forced or sustained loss of the provider control plane.
- **Impact: Critical.** Loss of the identity and control plane is a total loss of the ability to operate, approve and change, and it disables the mitigations in S1 (Sanctions, service suspension, geopolitical kill switch) and S2 (Extraterritorial laws, legal conflict, compelled actions) simultaneously.

Mitigating Actions

- **People:** Name an owner for the identity plane as a critical service in its own right, with the same continuity expectations as any production system, and give that owner authority over non-human identity.
- **Process:** Inventory and retire legacy and non-production identities. The Midnight Blizzard entry point

was a legacy non-production test tenant account without MFA, which is a governance failure, not a technology gap.³¹

- **Process:** Govern OAuth applications and service principals: least privilege, named owners, expiry, and periodic re-attestation of consent and permissions.
- **Process:** Define a graceful, time-bounded degraded mode with an explicit budget, for example "we can operate for N hours with local authentication and pre-authorized emergency access". Publish N, name who may operate in that mode, and make that list reachable without the systems that are down.
- **Technology:** Eliminate standing privilege in favor of just-in-time elevation, enforce phishing-resistant MFA on all administrative and non-human paths that support it, and keep break-glass accounts hardware-bound, monitored and rehearsed.
- **Technology:** Ensure critical local recovery paths do not depend on the same control plane they are meant to recover, and that credentials and runbooks for degraded mode are available offline.

How you would evidence this

- **Contractual:** Provider commitments on control-plane availability, regional independence of authentication paths, and what remains operable during a suspension or a regional failure.
- **Technical:** A complete inventory of human and non-human identities with standing privilege, the last attestation date per OAuth application, and MFA coverage figures broken down by identity type including service accounts and legacy protocols. Add evidence that break-glass credentials are stored outside the dependent system.
- **The test:** A timed disconnected-operation exercise, at least annually, for a named critical service. Sever the control-plane dependency in a controlled way and measure how long normal operations continue before the first business-visible failure. Publish the number and compare it against the N you claimed.
- **The second test:** A break-glass drill, quarterly, executed by an on-call engineer who is not the identity architect, with the primary identity path unavailable. If the drill needs the identity architect's phone, the drill failed.
- **The failure signature:** Coverage that stops at the boundary of the modern estate. MFA and conditional access protect the cloud applications, while a legacy domain, an on-premises server, or a service account sits outside them. That gap is the one attackers use. It is visible in your own risk register before it shows up in your incident report.

Downside / tradeoff

Engineering for disconnected survivability weakens live control. Local authentication paths, cached credentials, longer token lifetimes and standing local administrator rights are exactly the conditions that identity-plane attacks exploit for the 99 percent of time you are connected.

A permanently degraded posture is the worst answer. Running the whole estate at the level of its worst day pays the cost every day and still does not prove the disconnected mode works, because nothing has tested it.

The defensible position is a bounded degraded mode: identity strong, centralized and fast while connected, plus an explicitly time-limited fallback that you measure.

What it costs.

- **Money:** duplicate authentication infrastructure, offline credential custody, and the engineering to keep

a fallback path current with a platform that changes weekly.

- **People:** identity engineering is among the scarcest skills in the market, and the drills require people who are not the architect, which means training depth rather than a single expert.
- **Speed:** every hour of engineered disconnection tolerance costs you central enforcement and machine-speed response, and every untested hour of it costs you the capability without buying the survivability.

What makes sense, and what does not: the evaluation

Start with the position. Treat sovereignty as an enterprise risk managed through standard risk management practice. It is not binary, and the graded structure of the framework exists precisely so you do not have to treat it as binary.

What usually makes sense for most customers (Tier 1 to 2 workloads)

- **Target SEAL-2 (Data Sovereignty) or SEAL-3 (Digital Resilience) for the objectives that matter most,** typically SOV-2 (Legal and Jurisdictional Sovereignty), SOV-3 (Data and AI Sovereignty), SOV-4 (Operational Sovereignty) and SOV-7 (Security and Compliance Sovereignty), rather than "full sovereignty everywhere". In the framework's own terms that means EU law applicable and enforceable, with either material or marginal non-EU dependency accepted deliberately and written down. ¹
- **Reserve SEAL-4 (Full Digital Sovereignty) for the must-run few.** Full Digital Sovereignty means complete EU control with no critical non-EU dependencies, which is a description of a customer-operated environment and carries the whole cost profile in S1 (Sanctions, service suspension, geopolitical kill switch). ¹
- **Remember the scoring divergence.** This prioritization is risk-optimal and not score-optimal under the weighted Sovereignty Score, where SOV-5 (Supply Chain Sovereignty) alone carries twenty percent. ¹ Decide which you are optimizing for, per procurement, and say so.
- **Use the EU Data Boundary as the baseline** and Advanced Data Residency only where country-level commitments are necessary and eligible.
- **Implement Customer Lockbox and Data Guardian where operational access transparency is required,** and staff the approver rota before you switch the control on.
- **Use Customer-Managed Keys broadly.** Reserve Double Key Encryption and External Key Management for a narrow, genuinely critical data class, because key sovereignty increases operational complexity and reduces usability.
- **And check what "customer-managed" means in the specific service.** Key control limits what a provider can produce, not what a state can compel a provider to build, and it only holds where the provider never sees the key. A provider-managed key relabeled as customer-managed buys the paperwork and not the property.
- **Govern the identity and control plane as a critical service** (S4, Identity and control-plane dependency), and govern its non-human identity surface with the same seriousness as residency. This is where the documented compromises are.
- **Specify telemetry sovereignty explicitly,** because no framework will specify it for you. It serves S2 (Extraterritorial laws, legal conflict, compelled actions) and S4 (Identity and control-plane dependency) alike.

What only makes sense for exceptional cases (Tier 3 must-run)

- **Use Sovereign Private Cloud (Azure Local plus Microsoft 365 Local)** when business continuity requirements outweigh the loss of some hyperscale cloud benefits and functionality. SOV-1 (Strategic Sovereignty) explicitly includes resilience against service suspension and disrupted support. ¹

What usually does not make sense: sovereignty theater

- **Residency-only, without operational access governance and a key strategy**, fails to address the SOV-3 (Data and AI Sovereignty) and SOV-4 (Operational Sovereignty) realities of control over access, keys and operational oversight.
- **Declaring every workload must-run and forcing private sovereignty everywhere** increases cost and reduces innovation speed without proportional risk reduction. Organizations consistently underestimate the ongoing talent burden of operating those environments safely.
- **Claiming a SEAL level you have never exercised**. The framework will not stop you, because it grades control rather than proof and assesses from tender answers and documentation. ¹ A level with no test date behind it is a procurement artifact, and it will survive neither a supervisory review nor an incident.

Microsoft-centric control palette

Use this as a menu of controls in workshops and procurement. Each item states what it does and where it typically fits.

Data residency and processing controls

- **EU Data Boundary (Microsoft Cloud)**: Baseline commitment for eligible core services. It stores and processes customer data, and pseudonymized personal data, within the EU and EFTA. It also keeps professional services data from support interactions in the EU and EFTA for core services. ³³
- **Advanced Data Residency (ADR) for Microsoft 365**: Optional add-on for country-level residency commitments where eligible, and expanded service coverage beyond baseline commitments. ³⁴

Operational access control and transparency

- **Microsoft Purview Customer Lockbox**: Requires explicit customer approval before a Microsoft support engineer can access content during a support request. It covers Exchange Online, SharePoint Online, OneDrive for Business, Teams and Windows 365. Requests expire unapproved after 12 hours; granted access is capped at 4 hours. Requires E5-level licensing. It is scoped to support-engineer access in those services, not to every form of provider access. ³⁵
- **Data Guardian (Sovereign Public Cloud)**: Remote access by Microsoft personnel is approved and monitored by authorized Microsoft personnel resident in the region, with sessions logged to a tamper-evident ledger. This is provider self-supervision with regional separation of duty, not customer approval. It raises the cost and visibility of misuse and produces auditable evidence; where the approval decision must be the customer's, use Customer Lockbox. ³⁶

Encryption and key sovereignty

- **Customer-Managed Keys (CMK) with Azure Key Vault or Managed HSM**: Lets customers control encryption keys for many Azure services, with coverage varying by service. It supports separation of

duties and stronger key custody. Because the service can still decrypt with your authorization, search and scanning keep working, which is why CMK should be used broadly. ³⁷

- **Key control limit (applies to every item in this group):** controlling the key changes what the provider can produce, not what a government can order the provider to build. UK technical capability notices reach operator-applied protection ¹⁹, and Swiss NDG Article 43(2) requires operators to remove encryption they themselves applied. ²⁴ Whether a cloud or SaaS provider falls within that Swiss class is not settled, and Swiss case law on derived communications services suggests the category is read narrowly. ²² Read it as evidence that a European jurisdiction holds a strip-your-own-encryption power, not as a power that has been applied to a hyperscaler. Neither instrument reaches a key the customer holds and the provider never sees, so verify that is what you are buying.
- **Double Key Encryption (DKE) for Microsoft 365:** For highly sensitive data, it requires two keys to decrypt. One is customer-controlled, through a customer-operated DKE service, and one sits in Azure. So the provider cannot decrypt protected content without customer participation. ³⁸
- **What DKE costs you, specifically, because a procurement team will buy off this entry:** DKE-protected content is not searchable, not indexable, not available to eDiscovery, not DLP-scannable, not malware-scannable, and not visible to Copilot. ³⁸ That is the trade, and it is the right trade only for a narrow class of content.
- **External Key Management (Sovereign Public Cloud capability):** Designed to enable customer control of encryption keys outside Microsoft's cloud boundary, for example customer or trusted third-party HSMs, while still using Azure services. Used where regulations demand stronger separation of key custody. ³⁹

Confidential Computing (data in use protection)

- **Azure Confidential Computing (Confidential VMs and containers, TEEs):** Protects data in use by running computations inside hardware-based Trusted Execution Environments. This complements encryption at rest and in transit. It reduces the risk associated with operational access during processing. ⁴⁰
- **Secure key release via attestation (pattern):** Enables releasing keys only after the workload proves via attestation that it is executing inside a TEE, strengthening end-to-end control for sensitive workloads. ⁴⁰
- **Isolation model clarity:** Azure documents tenant isolation and hypervisor isolation as the layers that separate customers and workloads. ⁴¹ Hardware-rooted trust is documented separately, under confidential computing, where Microsoft states that "Azure uses a hardware root of trust that isn't controlled by the cloud provider". ⁴⁰ Keep the two claims apart in a tender answer: the isolation documentation does not support the hardware-root-of-trust claim.

Sovereign posture management at scale

- **Sovereign Control Panel (formerly Regulated Environment Management):** A unified Azure portal experience for viewing, managing and evaluating sovereignty posture across tenant resources, used with Sovereign Landing Zone policy-as-code guardrails. ⁴²

Deployment models for maximum autonomy

- **Sovereign Public Cloud (Microsoft Sovereign Cloud):** Applies sovereign controls across European datacenter regions, for services such as Azure, Microsoft 365, Security and Power Platform. It combines residency, operational oversight and encryption options. It does not require migrations for EU workloads already in region. ³⁹
- **Sovereign Private Cloud (Azure Local plus Microsoft 365 Local):** Customer-operated environment for extraordinary sovereignty needs (air-gapped, disconnected, must-run), enabling operation with full infrastructure control where public cloud dependency is unacceptable. Microsoft 365 Local means subscription editions of Exchange Server, SharePoint Server and Skype for Business Server on Azure Local, delivered through a certified partner and supported through at least 2035. It is not the Microsoft 365 cloud service: Teams, Copilot and the cloud-delivered security and compliance stack are given up for those workloads. ⁵
- **National Partner Clouds (where available):** Microsoft describes these as "independently operated cloud environments that deliver Microsoft Azure and Microsoft 365 capabilities under local ownership and control", for "scenarios where full ownership and operational independence from Microsoft is required". They are operated by local entities under national law, with Microsoft providing the technology stack. The named examples are Bleu in France, a joint venture of Orange and Capgemini designed to meet SecNumCloud requirements, and Delos Cloud in Germany, operated by an SAP subsidiary and aligned with German Cloud Platform Requirements. Availability and scope vary by geography. ⁴³
- **Azure Dedicated Host (clarifying note):** It provides single-tenant physical isolation, and the documentation states that "No other customer's VMs will be placed on your hosts". It also states that "Dedicated hosts are deployed in the same data centers and share the same network and underlying storage infrastructure as other, non-isolated hosts", and Microsoft continues to monitor, manage and service-heal them. ⁴⁴
- **The reading that follows is this paper's judgment, not the documentation's.** Microsoft makes no claim that a dedicated host alters jurisdiction or operatorship. So do not present it as a sovereignty control under SOV-1 (Strategic Sovereignty) or SOV-4 (Operational Sovereignty), and do not confuse it with the Sovereign Private Cloud models.

Regulatory alignment (governance and assurance)

- **NIS2 alignment:** Use NIS2 risk-management and reporting requirements as a governance baseline across critical sectors: board accountability, supply chain security, incident reporting. Article 23(4) sets the clock. An early warning "without undue delay and in any event within 24 hours of becoming aware of the significant incident", an incident notification within 72 hours of becoming aware, an intermediate report on request, and a final report "not later than one month after the submission of the incident notification". ⁴⁵
- **DORA alignment (financial services):** Use DORA for ICT risk management and ICT third-party risk management: contracts, auditability, resilience testing, and oversight for critical providers. Article 19 creates the obligation and the three-stage structure, but it leaves the timings to regulatory technical standards. ⁴⁶ Those timings sit in Commission Delegated Regulation (EU) 2025/301, Article 5(1): an initial notification within four hours of classifying the incident as major and no later than 24 hours from becoming aware, an intermediate report within 72 hours of the initial notification, and a final report no later than one month after the intermediate report. ⁴⁷

- **Do not run the two clocks off the same trigger.** DORA's first clock runs from classification of the incident as major, while NIS2's runs from awareness. DORA's final report runs from the intermediate report, while NIS2's runs from the incident notification. A single incident timeline that assumes the two are aligned will miss one of them.
- **Where the evidence blocks pay for themselves.** Both regimes ask for tested resilience and evidenced third-party oversight, not for asserted controls. The tests named in each scenario above are the same artifacts a NIS2 or DORA supervisor will ask for, so run them once and use the output twice.

The exercise calendar: sequencing and cost

This paper names an exercise in every scenario, and taken together that is a program, not a checklist. Counted as instances rather than as distinct exercise types, the four scenarios above call for several exercise runs a year.

Several of them compete for the same people. The break-glass drill and the disconnected-operation exercise land on the same small group of identity engineers. Both also require deliberate disruption of a production dependency.

If you schedule all of them in year one, none of them will happen properly. That is the most likely failure of this paper: a reader who agrees with the argument, sees the full set of commitments, and does nothing.

Year one: prove the things that fail silently

- **Quarter 1, the break-glass drill (S4, Identity and control-plane dependency).** Run by an on-call engineer who is not the identity architect. Cheap, disruptive only to the participants, and it exposes the offline credential custody gap immediately.
- **Quarter 2, the legal-demand tabletop (S2, Extraterritorial laws, legal conflict, compelled actions).** Two hours, mostly Legal and Architecture, no production impact.
- **Quarter 4, the timed exit rehearsal (S1, Sanctions, service suspension, geopolitical kill switch).** The most expensive exercise here. Run it once against one nominated critical workload, not against the estate.

Deliberately deferred to year two: the disconnected-operation exercise (S4, Identity and control-plane dependency) and the supplier substitution walkthrough (S3, Supply chain and sustainability resilience). Both need preparation that year one is producing.

Steady state

- **Quarterly:** the break-glass drill. It is short, it degrades fastest, and it is the one that fails at 03:00.
- **Annually:** timed exit rehearsal, disconnected-operation exercise, supplier substitution walkthrough, legal-demand tabletop.

What it costs

- **Money:** the quarterly drill is staff time only. The exit rehearsal and the disconnected-operation exercise are the two that need a target environment, and may need paid provider or partner involvement. Budget them as small projects rather than absorbing them. [INSERT: your own engineer-day rate and any partner fees.]
- **On that gap, deliberately.** No credible published benchmark exists for what a sovereignty exercise

program costs, and inventing a figure would undercut every other number in this paper. Estimate it against your own last tabletop: the people who were in the room, the hours they spent preparing, running and writing it up, and what the change window cost. That is a worse benchmark than an industry average and a far better estimate of what these will cost you.

- **People:** the binding constraint, not the budget. Most of this calendar lands on identity and platform engineers, which is exactly the group organizations already struggle to staff, in the labor market described earlier. Deliberately train a second person for each drill; a program that depends on one architect is a program with the same single point of failure it is meant to test.
- **Speed:** several exercises require planned degradation of a production dependency. Schedule them into change windows in advance and treat the disruption as the price of knowing, rather than discovering the same failure during an incident.

One rule holds the calendar together. Record the date each exercise last ran in the profile table, and let the empty cells drive the schedule. An exercise nobody has run is indistinguishable, on the page, from a control nobody has.

What this paper does not claim

A sovereignty paper is only as credible as the claims it refuses to make. Six in particular.

There is no publicly documented, named case of a CLOUD Act order against a named EU enterprise or government cloud customer. What exists in the public record is one aggregate line in one vendor transparency report.

That line is real and should be cited accurately. Microsoft's Government Requests for Customer Data report for July to December 2025 states: "Microsoft provided content data to U.S. law enforcement related to 3 non-U.S. enterprise customers whose data was stored outside the U.S. One of the 3 customers was located in the EU/EFTA." ⁴⁸

Cite the qualifier in the same breath, because it cuts in the customer's favor. The same report states that none of those disclosures involved Azure content data belonging to a commercial, public sector or educational customer. ⁴⁸

The vendor's own testimony sits alongside it and should be quoted, not summarized. On 10 June 2025 Microsoft France's Anton Carniaux appeared before the French Senate commission of inquiry. He was asked whether he could guarantee that data entrusted to Microsoft would never be transmitted following a US government injunction, without the explicit agreement of French authorities. His answer: "Non, je ne peux pas le garantir, mais, encore une fois, cela ne s'est encore jamais produit." ⁴⁹

The two are not necessarily inconsistent, since the testimony was June 2025 and the disclosure appears in the July to December 2025 reporting period. Present both, and note the timing. Note also that transparency reports are self-declared and not externally audited.

The one real hyperscaler cutoff of an entire country's customers, including access to stored data, was not a US action. It was Microsoft's March 2024 suspension for Russian companies, in compliance with the EU's twelfth sanctions package. ⁴ If your risk model assumes the kill switch is an American instrument, the only documented instance of it firing at national scale points the other way.

Do not make that case carry more than it can. N equals one. The customers were registered in a sanctioned state at war, and the instrument was a sanctions package rather than a discretionary decision by a provider or a government.

What it does establish is narrow and still useful. Service withdrawal at national scale is an available instrument. It can reach data already stored. And the jurisdiction that used it was European. What it does not establish is a base rate, or that a comparable action against an EU customer is likely.

The ICC prosecutor case is contested and should be disposed of on the record rather than omitted. It is the case most often raised from the floor in European sovereignty discussions, and it is the case least supported by uncontested facts.

What is reported and what is disputed. Press reporting in May 2025 stated that Microsoft canceled the email address of the ICC chief prosecutor, who had been targeted by a US executive order. Microsoft disputes that framing. Its president stated the company's actions "did not in any way involve the cessation of services to the ICC" ⁵⁰. A spokesperson said that "at no point did Microsoft cease or suspend its services to the ICC" ⁵⁰.

The defensible statement is narrow. An individual sanctioned by the US lost access to a Microsoft service. The extent of the provider's agency, and whether service to the institution itself was affected, is disputed by the provider and has not been independently established. Do not cite it as a proven kill switch.

The absence of documented cases has two defensible readings, and asserting only the first overstates. Either the risk is genuinely rare in practice, or the secrecy regimes are working exactly as designed: US non-disclosure orders, UK technical capability notice gagging obligations, French secret de la defense nationale.

There is at least one number that measures the second reading rather than asserting it. The same Microsoft report records that in the second half of 2025, thirty-two percent of US legal demands, 1,823 orders, carried secrecy orders. ⁴⁸ Whatever the public record shows, roughly a third of it was legally prohibited from being told to the customer.

Both readings are defensible and neither is provable from the public record. The honest position is that this is an asymmetry of evidence rather than a measured asymmetry of probability. One side of the comparison, ordinary attacker compromise, has thousands of forensically documented incidents. The other has no published base rate at all.

And the evidence on the compulsion side is unaudited vendor self-reporting, on all sides. This paper's strongest single data point comes from a transparency report the vendor writes about itself. No provider publishes an audited version, and the French Senate made that criticism to Microsoft directly on 10 June 2025. ⁴⁹

Turn that into a procurement question rather than a complaint. Ask every provider whether any part of its transparency reporting is externally assured, by whom, and to what standard. The answers, including the silences, are informative.

There is no published study comparing breach outcomes of self-hosted against cloud-operated environments, controlled for organization size and sector. It does not exist, and nothing in this paper should be read as implying it does.

So the argument here runs on observable mechanisms instead, each separately evidenced: multifactor coverage, patch latency, out-of-hours response capacity, and log retention. Those are measurable in your own estate, which is the point. Where a case is cited in this paper, it is cited for a named mechanism that failed, not as a verdict on an operating model.

One further limit. The AI-agent evidence base is young enough that Mandiant's own 2026 assessment is that the vast majority of successful intrusions still stem from fundamental human and systemic failures rather than AI. ⁵¹

Finally, date-stamp everything. Several load-bearing facts in this paper are on a clock. The e-Evidence Regulation applies from 18 August 2026.²⁶ The Swiss NDG and VUEPF revisions are in progress. And the UK Investigatory Powers Tribunal litigation continues. A sovereignty assessment is a snapshot, and it should say so.

Notes

1. Cloud Sovereignty Framework v1.2.1, European Commission, October 2025. Section 3 for the SEAL level definitions, section 5 for the weighted Sovereignty Score. https://commission.europa.eu/document/download/09579818-64a6-4dd5-9577-446ab6219113_en?filename=Cloud-Sovereignty-Framework.pdf
2. ENISA Threat Landscape 2025. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>
3. BSI, Cloud Computing Criteria Catalogue for Autonomy (C3A). Framework page: https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Empfehlungen-nach-Angriffszielen/Cloud-Computing/C3A/C3A_node.html and the catalogue download page, dated 27 April 2026: https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/CloudComputing/C3A_Cloud_Computing_Autonomy.html
4. Microsoft suspends access to cloud services for Russian companies, DatacenterDynamics, March 2024. <https://www.datacenterdynamics.com/en/news/microsoft-suspends-access-to-cloud-services-for-russian-companies/> - the underlying instrument is Council Regulation (EU) 2023/2878, the twelfth sanctions package, <https://eur-lex.europa.eu/eli/reg/2023/2878/oj> - with a wind-down date of 20 March 2024. Microsoft was among several providers that suspended services in that window.
5. Microsoft 365 Local overview. <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/private/m365-local/microsoft-365-local-overview>
6. Azure Stack Edge. Disconnected operation is a rugged SKU capability: <https://learn.microsoft.com/en-us/azure/databox-online/azure-stack-edge-pro-r-overview> Product family hub: <https://learn.microsoft.com/en-us/azure/databox-online/>
7. Azure Data Box: <https://learn.microsoft.com/en-us/azure/databox/data-box-overview>
8. Microsoft, European Digital Commitments, 30 April 2025, including the undertaking to contest government orders to suspend or cease European cloud operations. <https://blogs.microsoft.com/on-the-issues/2025/04/30/european-digital-commitments/> **Microsoft's published wording governs; nothing here modifies it.**
9. Erster Cyber-Katastrophenfall in Deutschland, Welt, 10 July 2021. <https://www.welt.de/politik/deutschland/article232427525/Anhalt-Bitterfeld-Hackerangriff-auf-Landkreis-loest-Katastrophenfall-aus.html>
10. Ransomware kostete Anhalt-Bitterfeld rund 2,5 Millionen Euro, heise online / dpa. <https://www.heise.de/news/Ransomware-kostete-Anhalt-Bitterfeld-rund-2-5-Millionen-Euro-9650816.html>
11. Microsoft Learn, "What is Microsoft Sovereign Cloud?", last updated 15 July 2026. <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/microsoft-sovereign-cloud>
12. Bundesamt fuer Sicherheit in der Informationstechnik, warning on the end of support for Exchange Server 2016 and 2019, 28 October 2025. https://www.bsi.bund.de/SharedDocs/Cybersicherheitswarnungen/DE/2025/2025-287772-1032_bits.html and the accompanying press release https://www.bsi.bund.de/DE/Service-Navi/Presse/Pressemitteilungen/Presse2025/251028_Support_Ende_Exchange-Server.html - the 92 percent is of the approximately 33,000 German on-premises Exchange servers known to the BSI with Outlook Web Access openly reachable from the internet. It is not a count of all Exchange servers in Germany.
13. Microsoft Learn, Product Lifecycle FAQ - Extended Security Updates. <https://learn.microsoft.com/en-us/lifecycle/faq/extended-security-updates> - note that the licensing mechanics described on this page are written around Windows Server and do not address Exchange Server.
14. Exchange Team Blog, "Released: August 2026 Exchange Server Security Updates", 11 August 2026. <https://techcommunity.microsoft.com/blog/Exchange/released-august-2026-exchange-server-security-updates/4543951>
15. CERT-Bund, quoted by heise online on 31 August 2026 following heise's inquiry to the BSI: "Currently, we are only aware of 9 Exchange servers 2016/2019 in Germany on which patches released as part of ESU are installed." English <https://www.heise.de/en/news/85-percent-of-on-prem-servers-in-Germany-vulnerable-11434806.html>; German original <https://www.heise.de/news/Exchange-Sicherheitsluecke-85-Prozent-der-On-Prem-Server-in-Deutschland-anfaellig-11434785.html>. The underlying statement is a CERT-Bund post of 28 August 2026 on the BSI's Mastodon account, independently dated by Help Net Security, 2 September 2026, <https://www.helpnetsecurity.com/2026/09/02/microsoft-exchange-cve-2026-62911-critical-authentication-bypass-flaw/>. **CERT-Bund's figure counts servers on which ESU patches were externally observable to CERT-Bund. It is not a count of ESU enrollments.**
16. ISC2 2025 Cybersecurity Workforce Study, 4 December 2025, 16,029 respondents. Global self-reported perception data from a certification body. <https://www.isc2.org/insights/2025/12/2025-ISC2-Cybersecurity-Workforce-Study>
17. European Commission, Extraterritoriality (Blocking statute), including the statement that the Annex "currently consists of U.S. measures concerning Cuba and Iran". https://finance.ec.europa.eu/eu-and-world/open-strategic-autonomy/extraterritoriality-blocking-statute_en - the instrument itself is Council Regulation (EC) No 2271/96. <https://eur-lex.europa.eu/eli/reg/1996/2271/oj/eng>
18. European Commission, Extraterritoriality (Blocking statute), the page carrying the 2021 initiative to amend Council Regulation (EC) No 2271/96. https://finance.ec.europa.eu/eu-and-world/open-strategic-autonomy/extraterritoriality-blocking-statute_en - the consolidated text of the Regulation, showing no amendment since 2018, is at <https://eur-lex.europa.eu/eli/reg/1996/2271/2018-08-07/eng>
19. Investigatory Powers Act 2016, section 253. <https://www.legislation.gov.uk/ukpga/2016/25/section/253>

20. Articles L871-1 to L871-7, Code de la securite interieure. https://www.legifrance.gouv.fr/codes/section_lc/LEGITEXT000025503132/LEGISCTA000030937362/ [↗](#)
21. BUEPF / SPTA SR 780.1, unofficial English translation (English has no legal force). https://lawbrary.ch/gesetz/cc/780_1/B%C3%9CPF/v2021.01/en/art26/federal-act-on-the-surveillance-of-post-and-telecommunications-spta/art26-obligations-of-providers-of-telecommunication/ [↗](#)
22. Swiss Federal Supreme Court, judgment 2C_544/2020 of 29 April 2021 (Threema), upholding Federal Administrative Court judgment A-550/2019 of 19 May 2020, on the lighter Article 27 BUEPF duties for providers of derived communications services. Judgment text of the Federal Administrative Court decision: http://www.digitale-gesellschaft.ch/uploads/2020/06/Urteil-Threema-A-550_2019.pdf The Federal Supreme Court judgment is cited here by its reference, 2C_544/2020; the following page is law-firm commentary reporting it, not the judgment itself: <https://core-attorneys.com/news-insights/bundesgericht-threema-a-gilt-nicht-als-fernmeldedienstanbieterin-im-sinne-des-buepf/> [↗](#) [↗](#)
23. BUEPF Article 27(3), with VUEPF Article 22(4) and Article 52, allowing the Federal Council to impose the heavier telecommunications duties on a derived-service provider case by case. [INSERT: links.] [↗](#)
24. NDG SR 121, Article 43, covering in Article 43(2) both the signal-delivery duty and, in the second sentence of the same paragraph, the removal of encryption applied by the operator. Official text in force 1 January 2024: <https://lawbrary.ch/law/art/NDG-v2024.01-de-art-43/> Bilingual text: <https://www.droit-bilingue.ch/de-rm/1/12/121-43-46.html> [↗](#) [↗](#)
25. PRC Data Security Law, Article 36, official English text. http://www.npc.gov.cn/englishnpc/c2759/c23934/202112/t20211209_385109.html [↗](#)
26. Regulation (EU) 2023/1543 on European Production and Preservation Orders, and Directive (EU) 2023/1544. <https://eur-lex.europa.eu/eli/reg/2023/1543/oj/eng> [↗](#) [↗](#)
27. Bundesverfassungsgericht, judgment of 19 May 2020, 1 BvR 2835/17, press release 37/2020. <https://www.bundesverfassungsgericht.de/SharedDocs/Pressemitteilungen/EN/2020/bvg20-037.html> [↗](#)
28. Microsoft, Defending your data, 19 November 2020. <https://blogs.microsoft.com/on-the-issues/2020/11/19/defending-your-data-edpb-gdpr/> - the major cloud providers each publish their own commitments in this area and are signatories to the Trusted Cloud Principles. No comparison between them is made or implied here. [↗](#)
29. Microsoft, secrecy order lawsuit archive. <https://blogs.microsoft.com/datalaw/initiative/legal-cases/microsofts-secrecy-order-lawsuit/> - and Brad Smith, "DOJ acts to curb the overuse of secrecy orders", 23 October 2017. <https://blogs.microsoft.com/on-the-issues/2017/10/23/doj-acts-curb-overuse-secrecy-order-s-now-congress-turn/> - note that United States v. Microsoft Corp., 584 U.S. (2018) was vacated as moot following the CLOUD Act rather than decided in Microsoft's favor. [↗](#)
30. European Data Protection Board, Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data, version 2.0 adopted 18 June 2021. https://www.edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-012020-measures-supplement-transfer_en - used here in place of the IAPP transfer impact assessment reference in the base document, because no current stable IAPP page for that guidance could be verified. [↗](#) [↗](#)
31. Microsoft, Midnight Blizzard: guidance for responders, 25 January 2024. <https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/> [↗](#) [↗](#)
32. US Cyber Safety Review Board, Review of the Summer 2023 Microsoft Exchange Online Intrusion, 2024, published via CISA. <https://www.cisa.gov/resources-tools/resources/CSRB-Review-Summer-2023-MEO-Intrusion> The Board's findings, including its criticism of the company, are quoted from that report. Verify the current location of the document before publication: the Board's members were removed in January 2025. [↗](#)
33. EU Data Boundary: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-learn> and, because this paper's own advice is to read the scope list, the ongoing partial transfers page: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-ongoing-partial-transfers> [↗](#)
34. Advanced Data Residency: <https://learn.microsoft.com/en-us/microsoft-365/enterprise/advanced-data-residency> [↗](#)
35. Microsoft Purview Customer Lockbox: <https://learn.microsoft.com/en-us/purview/customer-lockbox-requests> [↗](#)
36. Data Guardian: <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/public/data-guardian> [↗](#)
37. Microsoft, Azure data encryption at rest and encryption models, the source of the quoted wording that server-side encryption with platform-managed keys means the service has full access to store and manage the keys. <https://learn.microsoft.com/en-us/azure/security/fundamentals/encryption-models> - Customer-Managed Keys are implemented per service and coverage varies by service, so read this together with the specific service documentation and the Azure Key Vault documentation. [↗](#)
38. Double Key Encryption: <https://learn.microsoft.com/en-us/purview/double-key-encryption> [↗](#) [↗](#)
39. External Key Management. No standalone page confirmed; see the Sovereign Public Cloud capabilities page: <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/public/sovereign-public-cloud-capabilities> [↗](#) [↗](#)
40. Azure Confidential Computing: <https://learn.microsoft.com/en-us/azure/confidential-computing/overview> [↗](#) [↗](#) [↗](#)
41. Microsoft Learn, Azure isolation choices. <https://learn.microsoft.com/en-us/azure/security/fundamentals/isolation-choices> - this page supports tenant and hypervisor isolation. It does not describe a hardware root of trust. [↗](#)
42. Microsoft Sovereign Control Panel, formerly Regulated Environment Management, and Sovereign Landing Zone guardrails. <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/public/sovereign-control-panel> [↗](#)
43. Microsoft Learn, Overview of National Partner Clouds. <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/partner/overview-national-partner-clouds> [↗](#)
44. Microsoft Learn, Azure Dedicated Host. <https://learn.microsoft.com/en-us/azure/virtual-machines/dedicated-hosts> [↗](#)
45. Directive (EU) 2022/2555 (NIS2), Article 23(4), OJ L 333, 27.12.2022, p. 80. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng> [↗](#)
46. Regulation (EU) 2022/2554 (DORA), Article 19, OJ L 333, 27.12.2022, p. 1. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng> [↗](#)

47. Commission Delegated Regulation (EU) 2025/301 of 23 October 2024, Article 5(1), OJ L, 2025/301, 20.2.2025. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj/eng ↩
48. Microsoft, Government Requests for Customer Data report, July to December 2025. <https://www.microsoft.com/en-us/corporate-responsibility/reports/government-requests/customer-data> - the most recent reporting period available at the time of writing; check for a later one before publication. ↩ ↩ ↩
49. Senat francais, compte rendu, commission d'enquete sur la commande publique, 10 June 2025. https://www.senat.fr/compte-rendu-commissions/20250609/ce_commande_publique.html ↩ ↩
50. Microsoft's disputed account of the ICC matter, including "did not in any way involve the cessation of services to the ICC", reported by Politico Europe, June 2025. <https://www.politico.eu/article/microsoft-did-not-cut-services-international-criminal-court-president-american-sanctions-trump-tech-icc-amazon-google/> ↩ ↩
51. Mandiant / Google Cloud, M-Trends 2026, 23 March 2026. <https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026/> - vendor-defined and not independently audited. ↩